DeepTrustxAI Cloud Attack Paths and Evidence-Driven Defense Workshop

Training Format

- Duration: 2 days, 8 hours per day including breaks
- Level: Intermediate to advanced
- Delivery: Instructor-led, lab-heavy, team-based
- Audience: Cloud security, DevOps, SRE, platform engineering, SOC, GRC, and scanner-product teams
- Lab rule: Only approved disposable cloud accounts, projects, namespaces, and local clusters
- Final output: Attack-path narrative, scanner evidence, control mapping, remediation plan, and five-minute executive briefing

Learning Outcomes

Participants will be able to:

- Explain cloud compromise as a chain across exposure, identity, workload, data, and control-plane permissions.
- Compare equivalent weaknesses across AWS, Azure, GCP, DigitalOcean, Kubernetes, and developer platforms.
- Validate a weakness manually inside an authorized lab and compare it with scanner output.
- Normalize evidence through a connector contract that includes `tenant_id` and scan lineage.
- Map findings to control status, owner, severity, remediation, and audit proof.
- Design safer scanner workflows with queues, workers, evidence processors, and tenant isolation.
- Present the highest-risk attack path to leadership in plain language.

Module Map

Module	Duration	Focus	Hands-on outcome	Evidence output
0. Orientation and setup	30 min	Authorization, tenants, portal and evidence flow	Trigger a dry run and validate tenant routing	Job event and accepted evidence
1. Multi-cloud attack-path mindset	60 min	Exposure-to-impact chains	Build an attack graph from a scenario	Attack graph and control draft

Module	Duration	Focus	Hands-on outcome	Evidence output
2. Recon to first foothold	90 min	Inventory gaps and exposed assets	Enumerate only assigned lab assets	Asset list and scanner comparison
3. Storage and artifact exposure	75 min	Buckets, backups, logs and build artifacts	Review a vulnerable storage policy	Policy snapshot and remediation diff
4. SSRF, metadata and cloud identity	75 min	Runtime identity exposure	Trace a controlled application-to-identity path	Metadata posture and permission snapshot
5. Serverless and data tier	60 min	Functions, queues, databases and secrets	Compare manual configuration review with scanner findings	Function, secret and data exposure evidence
6. Containers and Kubernetes	75 min	Workloads, RBAC, network policy and drift	Scan a test cluster with kubeconfig	Cluster inventory, RBAC and drift findings
7. IAM escalation graph	75 min	Trust relationships and privilege paths	Mark dangerous identity-graph edges	Permission graph and least-privilege plan
8. Provider-specific kill chains	75 min	AWS, Azure, GCP and DigitalOcean equivalence	Normalize four provider mini-cases	Provider comparison and evidence payloads
9. CI/CD, developer platforms and AI	60 min	OIDC, tokens, build artifacts and agents	Review a vulnerable workflow and define guardrails	CI/CD finding and AI boundary recommendation
10. Defenses that work	45 min	Prevention, detection, response and proof	Convert findings into owned controls	Control matrix and remediation tickets
Capstone	60 min	End-to-end investigation and briefing	Identify, prove and explain the highest-risk path	Evidence bundle and executive briefing

Module 0: Orientation and Setup

Objective

Establish authorization boundaries, confirm lab access, and explain the scanner-to-evidence workflow.

Topics

- Rules of engagement and stop conditions
- Lab account and tenant assignment
- Portal, scanner workers, evidence connectors, queue, processor, and dashboard
- `tenant_id` segregation and credential references
- Evidence quality and capstone scoring

Exercise

1. Log in to the training portal.
2. Confirm the assigned tenant and disposable lab identifier.
3. Trigger a dry-run scanner job.
4. Upload a sample evidence record.
5. Verify that no other tenant can see the job or evidence.

Instructor Preparation

- One known-good tenant and one negative-test tenant
- Sample evidence JSON with a valid and invalid `tenant_id`
- Dry-run worker or prerecorded fallback

Module 1: Multi-Cloud Attack-Path Mindset

Objective

Teach participants to model cloud breaches as connected control failures rather than isolated findings.

Topics

- External exposure versus identity exposure
- Data plane versus control plane
- Identity graph edges and blast radius
- Common patterns across providers
- Mapping attack-path stages to scanner and GRC evidence

Exercise

Teams receive a short breach story and convert it into:

- Entry point
- Identity obtained or abused
- Privilege path
- Sensitive asset reached
- Missing prevention and detection controls
- Evidence source for each stage

Module 2: Recon to First Foothold

Objective

Identify how asset inventory gaps and intentional public exposures create initial-access opportunities in an authorized lab.

Topics

- Public object storage and exposed services
- Debug endpoints, stale DNS, and build artifacts
- Safe inventory collection inside assigned scope
- Manual evidence versus scanner coverage

Exercise

- Enumerate only instructor-assigned assets.
- Record exposed services and intended ownership.
- Capture non-sensitive proof.
- Run the inventory scanner and compare misses, duplicates, and false positives.

Module 3: Storage and Artifact Exposure

Objective

Understand how object storage policies, backups, logs, and build artifacts expose sensitive information.

Topics

- Public and cross-account access
- Over-broad bucket/container policies
- Backup and log exposure
- Secrets in artifacts
- Safe handling, hashing, and retention of evidence

Exercise

- Review a prepared vulnerable storage configuration.
- Classify the exposed artifact without displaying real secrets.

- Validate scanner detection.
- Produce a least-privilege policy change and before/after evidence.

Module 4: SSRF, Metadata and Cloud Identity

Objective

Explain how an application weakness can become cloud-identity exposure, while keeping all activity inside a controlled lab.

Topics

- Metadata services and runtime identities
- Short-lived credentials and effective permissions
- Metadata hardening, egress controls, and application fixes
- Shared ownership between application and cloud teams

Exercise

- Review a controlled SSRF-style lab trace supplied by the instructor.
- Identify the metadata protection setting and attached identity.
- Determine the blast radius from effective permissions.
- Write a remediation note with separate application and cloud owners.

Module 5: Serverless and Data Tier

Objective

Identify lateral-movement risk created by automation identities, functions, queues, databases, and secret stores.

Topics

- Over-privileged function roles
- Sensitive environment variables and build-time secrets
- Public or overly broad database access
- Queue-triggered workflows and detection opportunities

Exercise

- Review a vulnerable function configuration.
- Identify excessive permissions and sensitive configuration classes.
- Compare manual review with scanner evidence.
- Map each finding to a preventive and detective control.

Module 6: Containers and Kubernetes

Objective

Assess workload, identity, network, secret, and IaC-drift risk in a disposable cluster.

Topics

- Image and dependency risk
- Privileged workloads and host mounts
- Service accounts, Roles, ClusterRoles, and bindings
- Exposed services and missing NetworkPolicies
- Live-state versus manifest drift

Exercise

- Connect with the assigned kubeconfig.
- Review pods, services, namespaces, RBAC, secrets exposure patterns, and network policies.
- Compare live state with the provided IaC manifests.
- Rank findings by blast radius and remediation effort.

Module 7: IAM Escalation Graph

Objective

Recognize privilege paths created by trust policies, broad actions, service agents, and CI/CD identities.

Topics

- Identity graph construction
- Role chaining and trust conditions
- Dangerous create/update/pass/assume relationships
- Permission boundaries, deny policies, and break-glass exceptions
- Evidence for engineers versus auditors

Exercise

- Build a graph from lab IAM relationships.
- Mark the highest-risk edges.
- Validate them with scanner output.
- Produce a least-privilege remediation plan with an exception path.

Module 8: Provider-Specific Kill Chains

Objective

Compare similar control failures across AWS, Azure, GCP, DigitalOcean, and developer platforms.

Provider Map

Control area	AWS	Azure	GCP	DigitalOcean
Identity	IAM role/policy	Entra ID and managed identity	Project IAM and service account	Teams, projects and API tokens
Storage	S3	Storage account/blob	Cloud Storage	Spaces
Runtime	EC2/Lambda/EKS	VM/Functions/AKS	Compute/Functions/GKE	Droplet/Functions/DOKS
Data	RDS/DynamoDB	Azure SQL/Cosmos DB	Cloud SQL/Firestore	Managed databases
Evidence	CloudTrail/config APIs	Activity logs/resource graph	Audit logs/asset inventory	API inventory and service logs

Exercise

Teams normalize four mini-cases into the same evidence schema without carrying provider-specific terminology into the control name.

Module 9: CI/CD, Developer Platforms and AI

Objective

Understand how repositories, runners, deployment platforms, model endpoints, and AI agents become cloud-adjacent control planes.

Topics

- OIDC trust, branch restrictions, and token scope
- Deployment environment variables and build logs
- Artifact and cache exposure
- AI agents with cloud or scanner permissions
- Private model hosting and OpenAI-compatible endpoints
- Action logging, approval gates, redaction, and cost controls

Exercise

- Review a vulnerable workflow definition.
- Identify excessive token or cloud permissions.
- Create a normalized connector payload.
- Define a permission boundary and approval rule for AI-assisted scanning.

Module 10: Defenses That Work

Objective

Convert technical findings into durable controls with owners and proof requirements.

Control Model

Layer	Required question	Evidence example
Prevent	What stops the weakness from being introduced?	Policy-as-code result or permission boundary
Detect	What identifies the condition or abuse?	Scanner run, audit log, drift alert
Respond	Who owns containment and remediation?	Ticket, due date, exception approval
Prove	What demonstrates closure?	Before/after configuration and rescanned result

Capstone

Scenario

A newly onboarded tenant has intentional weaknesses across IaC, cloud IAM, storage, Kubernetes, and CI/CD. Teams must identify the most important attack path, validate it through scanner evidence, map it to controls, and explain the fix.

Deliverables

- Attack-path narrative
- Scanner result export
- Evidence connector payloads
- Compliance dashboard findings
- Control mapping
- Remediation plan
- Five-minute leadership briefing

Scoring

- 20 points: Accurate attack path

- 20 points: Evidence quality and tenant segregation
- 20 points: Scanner validation and deduplication
- 15 points: Control mapping
- 15 points: Remediation quality
- 10 points: Executive communication

Common Evidence Contract

Every scanner or connector should provide:

- `tenant_id`
- `source_system` and `scanner_type`
- `scan_job_id`
- `asset_id`, `asset_type`, provider, and region
- `finding_id`, title, severity, and status
- `control_ids`
- `evidence_type` and `evidence_uri`
- `observed_at`
- remediation recommendation

Raw credentials must never be included in a finding or evidence payload. Store only an encrypted credential reference scoped to the tenant and scanner type.

Workshop Safety Checklist

- Written authorization and assigned target list are confirmed.
- Labs are isolated from production accounts and production networks.
- Budgets, quotas, region restrictions, and expiry tags are active.
- Lab credentials are least privilege and time limited.
- No public target or third-party asset is scanned.
- No real secret is stored in a vulnerable fixture.
- Reset and cleanup procedures have been tested.
- A backup TTL cleanup worker is active for temporary cloud resources.
- Evidence is tenant-scoped and redacted before presentation.
- All credentials are rotated or destroyed after the workshop.

Instructor Delivery Checklist

- Run a full dry run at least three days before delivery.
- Keep prerecorded scanner outputs and sample evidence as a fallback.
- Verify every lab has a clean reset path.
- Confirm the portal, queue, workers, database, object storage, and connectors are healthy.
- Prepare a known-good capstone answer and scoring sheet.
- Monitor cloud cost and active lab resources throughout the workshop.
- Export the evidence bundle and audit trail before final teardown.

Source and Brand Notes

- DeepTrustxAI brand logo: official asset from `https://deeptrustxai.com/images/darkmode.png`.
- Curriculum scope reference: public DEF CON Training listing for "Breaking the Cloud Layer - Modern and Practical Attacks on AWS, Azure, GCP, Aliyun, Railway and Vercel."
- All slides and exercises in this package are original internal workshop material and are restricted to authorized lab environments.